LAB-01 — Protección y privacidad de datos

Materia: Gestión de Seguridad y Desempeño de Bases de Datos
Unidad: II — Seguridad, privacidad y control de acceso
Actividad: Actividad 2 — Enmascaramiento
Estudiante: Carlos Romero
Grupo: 4

Actividad 2 — Enmascaramiento

Objetivo

El objetivo de esta actividad es proteger parte de la información personal almacenada en la tabla clientes, permitiendo que el área de soporte pueda consultar únicamente los datos necesarios para realizar sus funciones.

Para ello se implementó una vista en PostgreSQL que muestra de manera parcial el correo electrónico, el teléfono y el RFC de los clientes, evitando que el rol de soporte tenga acceso directo a los valores originales.

Debido a que el servidor PostgreSQL de FICLabs es compartido y el rol soporte ya existía, se utilizó el rol soporte_23101075 para evitar conflictos con otros usuarios del sistema.

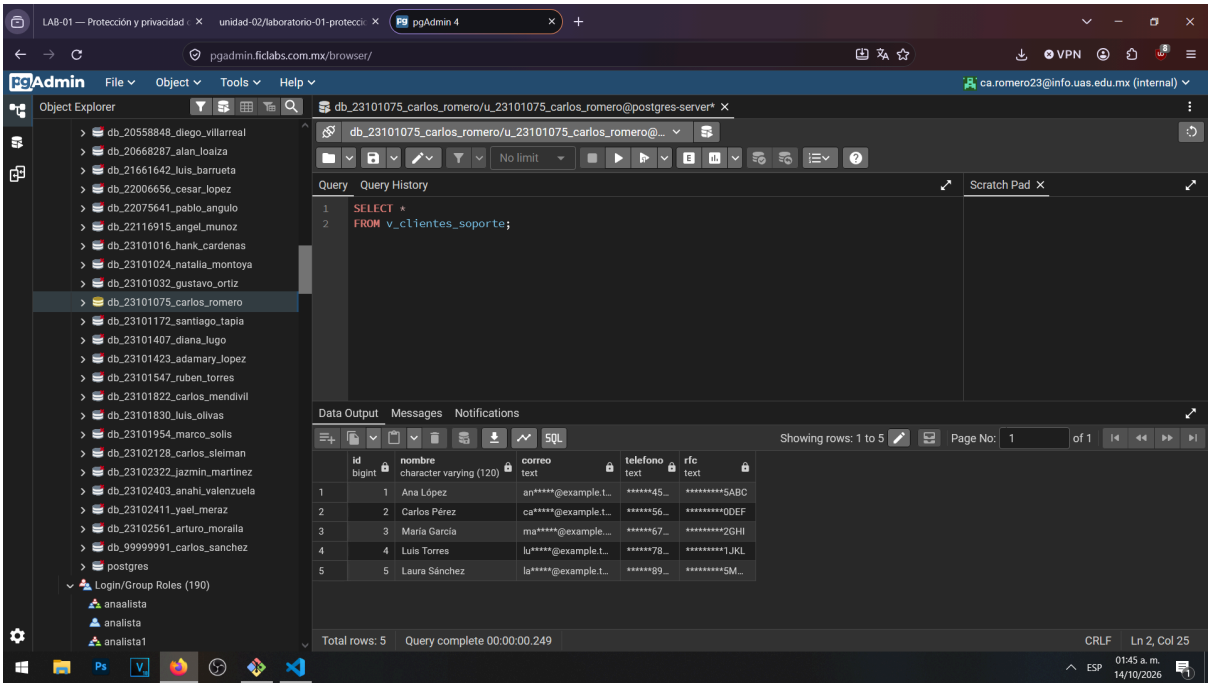
Evidencia 1 — Vista con información enmascarada

Se creó la vista v_clientes_soporte, la cual muestra el identificador y nombre de los clientes, pero oculta parcialmente el correo electrónico, teléfono y RFC.

La consulta utilizada para verificar la vista fue:

```
SELECT *
FROM v_clientes_soporte;
```

Captura de evidencia



Resultado

La consulta muestra correctamente los cinco registros almacenados en la tabla de clientes.

El correo electrónico se presenta parcialmente oculto, conservando únicamente los primeros caracteres y el dominio.

El número telefónico conserva únicamente los últimos cuatro dígitos, mientras que el RFC muestra solamente sus últimos cuatro caracteres.

De esta manera, el área de soporte puede utilizar la información necesaria sin visualizar completamente determinados datos personales.

Evidencia 2 — Verificación de privilegios

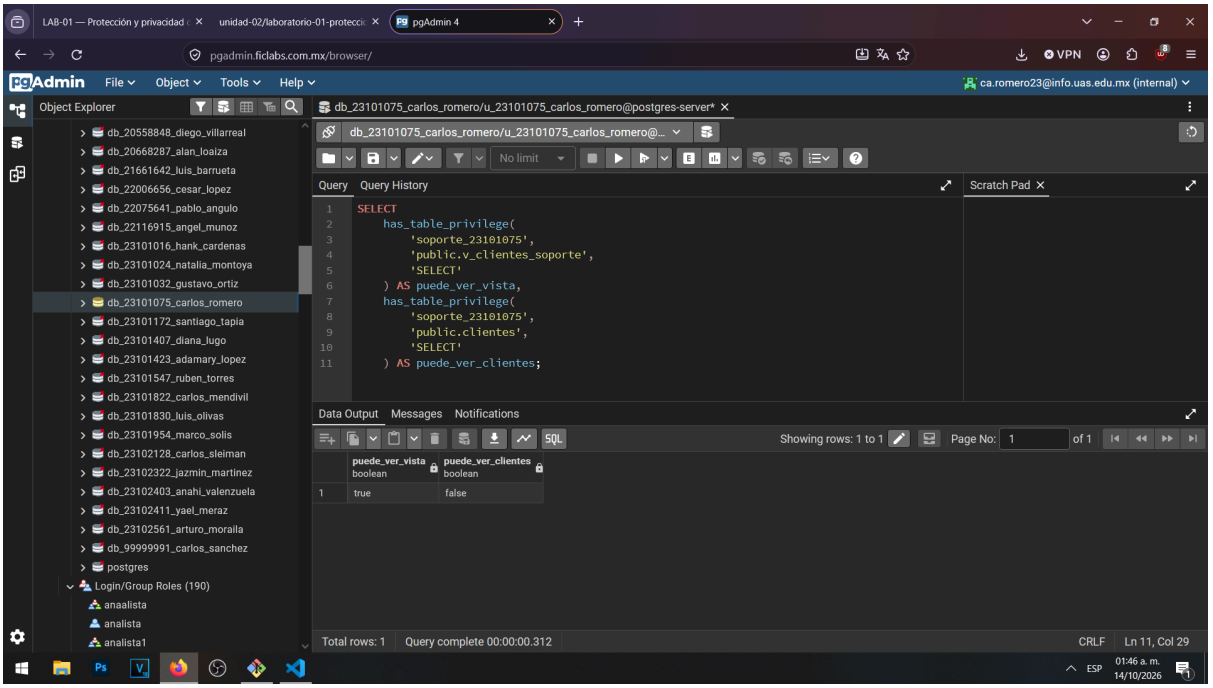
Se verificaron los privilegios asignados al rol soporte_23101075 mediante la función has_table_privilege.

La consulta utilizada fue:

```
SELECT
    has_table_privilege(
        'soporte_23101075',
        'public.v_clientes_soporte',
        'SELECT'
    ) AS puede_ver_vista,
    has_table_privilege(
        'soporte_23101075',
        'public.clientes',
```

'SELECT'
) AS puede_ver_clientes;

Captura de evidencia



Resultado

El resultado demuestra que el rol soporte_23101075 tiene permiso para consultar la vista v_clientes_soporte.

Al mismo tiempo, se verifica que no cuenta con privilegio SELECT sobre la tabla original clientes.

Esto demuestra la aplicación del principio de mínimo privilegio, ya que el rol recibe únicamente los permisos necesarios para realizar su función.

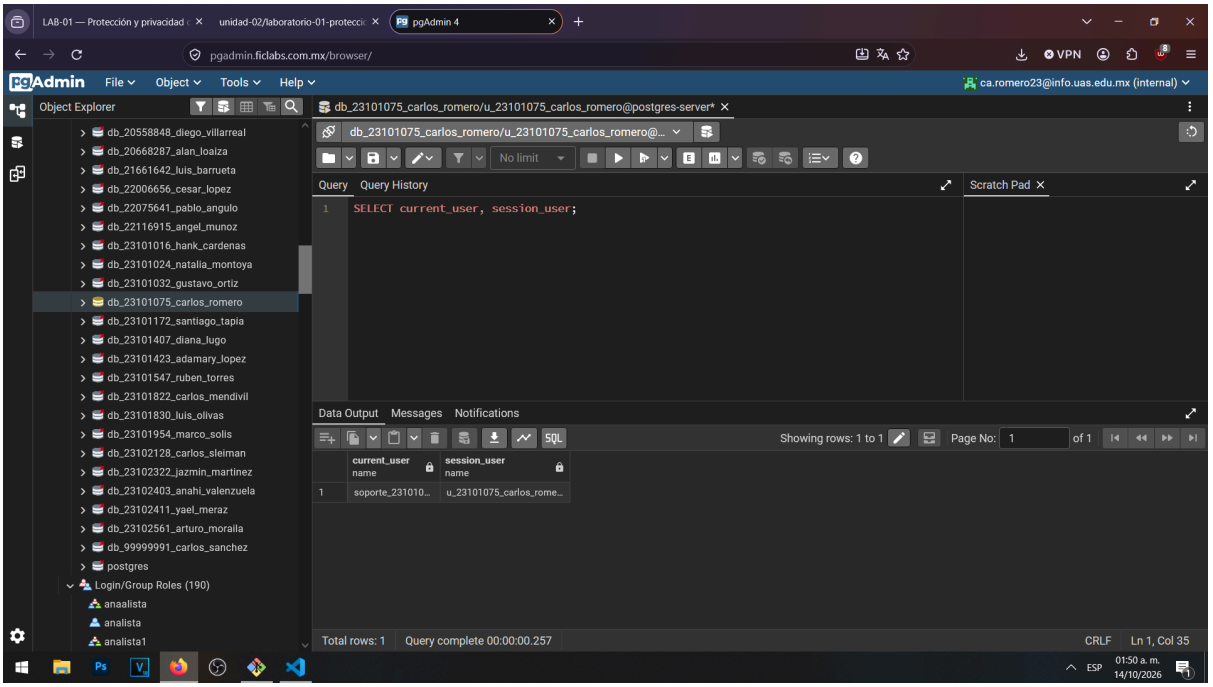
Evidencia 3 — Verificación del rol activo

Para comprobar los permisos directamente desde la perspectiva del área de soporte, se utilizó SET ROLE.

Posteriormente se verificó el usuario efectivo y el usuario original de la sesión mediante:

SELECT current_user, session_user;

Captura de evidencia



Resultado

El campo current_user muestra que los privilegios efectivos corresponden al rol soporte_23101075.

El campo session_user conserva el usuario original utilizado para iniciar la sesión en FICLabs.

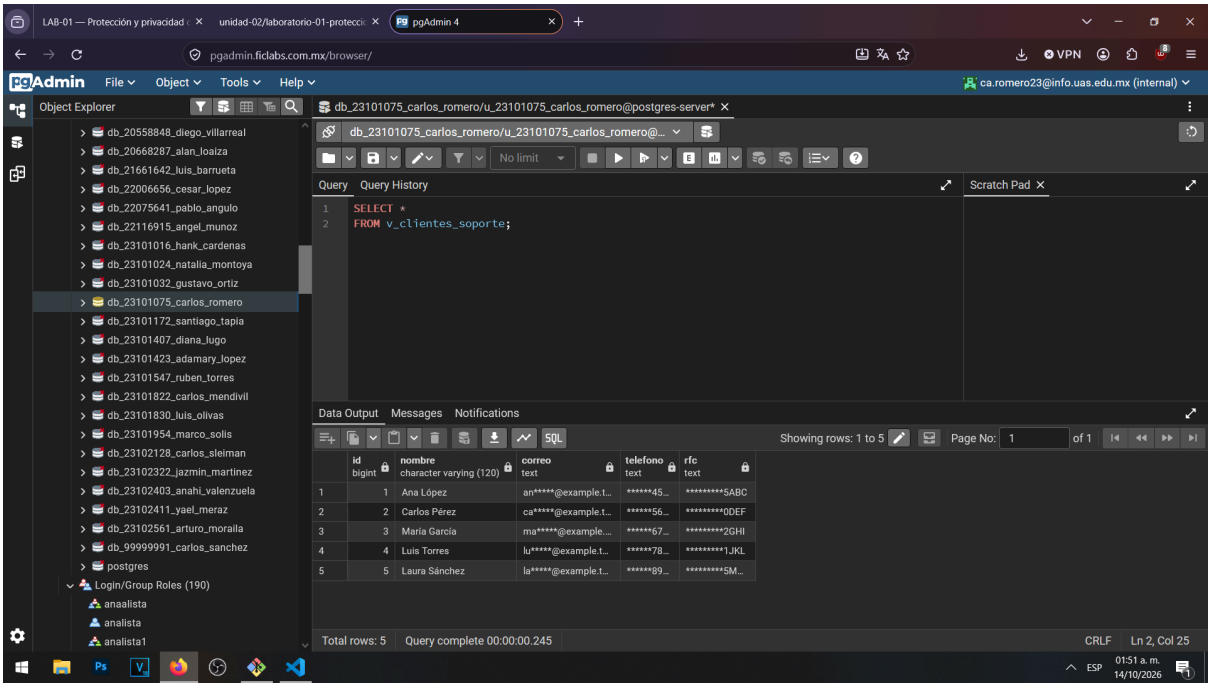
Esto permite demostrar que las siguientes consultas se ejecutan realmente utilizando los permisos asignados al rol de soporte.

Evidencia 4 — Consulta permitida con el rol de soporte

Con el rol soporte_23101075 activo se consultó nuevamente la vista protegida:

```
SELECT *
FROM v_clientes_soporte;
```

Captura de evidencia



Resultado

La consulta se ejecutó correctamente y mostró los cinco registros con los datos personales parcialmente ocultos.

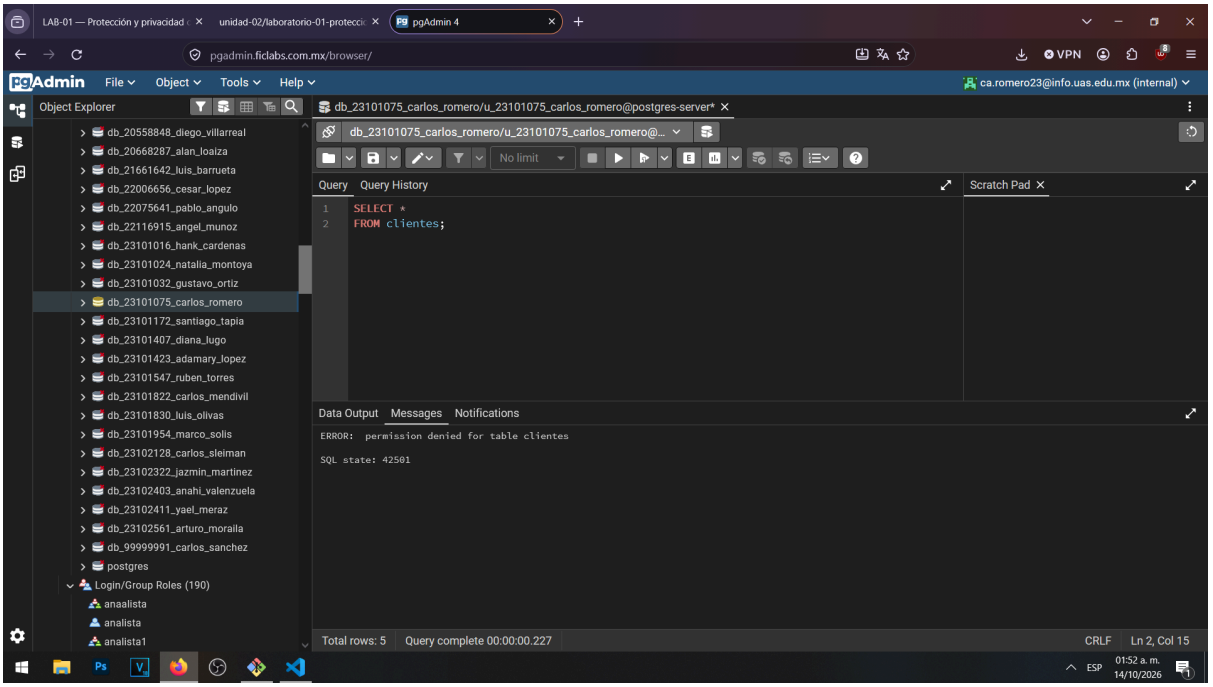
Esto demuestra que el rol de soporte cuenta con los permisos necesarios para utilizar la vista creada, sin requerir acceso directo a los datos originales.

Evidencia 5 — Acceso directo rechazado

Finalmente, con el rol soporte_23101075 todavía activo, se intentó consultar directamente la tabla original mediante:

```
SELECT *
FROM clientes;
```

Captura de evidencia



Resultado

PostgreSQL rechazó el acceso directo a la tabla clientes y mostró el mensaje:

ERROR: permission denied for table clientes
SQL state: 42501

Este resultado demuestra que el rol soporte_23101075 no puede consultar directamente los datos originales.

El acceso únicamente está permitido a través de la vista v_clientes_soporte, donde los datos sensibles se presentan parcialmente enmascarados.